IriusRisk Key Terms

Diagramming Key Terms

Trust Zone
Defines the level of trust for different regions of our threat model. Zones which are less trusted are more likely to see threats realized vs a higher trusted zone. They have a numerical value from 1 - 100. That value is used when determining the likelihood of impact score when calculating inherent risk for a threat.

Component
A component can represent almost anything in a diagram. It might be a service or a server but they generally have some risk pattern or threat attached to them. For now, just recognize that they are the building blocks of a threat model. We add components to describe our application and deconstruct its functionality or architecture.

Component Questionnaire
A component level questionnaire that allows me to collect additional information about my component, its relationship with other components, and any additional information that might influence my overall risk. These questionnaires are also used to assign assets to specific components.

Assets
Assets are functionally the data that a threat modeler is trying to protect. Each asset has a security classification which defines the impact to the organization if that asset is compromised. Each classification provides an impact score for the Confidentiality, Integrity, and Availability of that asset.

Data Flow
Data flows represent the flow of data (assets) from one component to another. They can have tags (assets or other indicators) attached to them. Those tags and assets can then be used with the rules engine to import other risks/threats into the threat model. They can also be used to move selected countermeasures into an implemented status.

Update Threat Model
When the update threat model button is pushed the rules engine goes through and reviews all the components, questionnaires, custom fields, data flows, and tags and begins the process of adding risks and threats, and countermeasures to the threat model. This is the backbone of IriusRisk and provides the user with the ability to scale a library of threats and countermeasures to multiple users in a consistent manner.

Artifact
Artifacts are point in time saves which include a full display of the diagram. This only includes the diagram and does not include the actual threat model or any associated component questionnaire answers.

Project Setup Key Terms

Project
In IriusRisk, we create threat models which are also referred to as Projects or Products. These are generally interchangeable terms. Inside of the product, each project consumes a single license while it is actively in the list of projects.

Name
Also known as project name. This is the friendly name for the threat model.

Reference ID
This is usually the same as project name but will only be lower case and has underscores separating each word. Generally when referencing this project through the API, you would use the reference ID. Once the reference ID for a project has been set, it cannot be changed.

Architecture Questionnaire
Unlike the component questionnaire which is specific to each component, the architecture questionnaire applies to the full threat model.

General Threats
In IriusRisk, there are two different types of threats - General Threats and Component based threats. General threats apply to everything in my project. Component level threats only apply to specific components which are a subset of the whole project.

Threats and Countermeasures Key Terms

Threat
Threats are ultimately the bad things that will happen if a weakness is realized. Threats are the events which ultimately lead to the loss of confidentiality, integrity, and availability for assets assigned to components.

Weakness
Reflects a scenario that might allow for a threat to be realized.

Threat Impact
These three impacts demonstrate the impact that this threat will have on those three functional areas of an asset (Confidentiality, Integrity, and Availability) if realized. Not all threats will impact data in the same fashion.

Use Case
Method for organizing and grouping sets of threats. Types of use cases might include - Authentication, Authorization, Logging and Monitoring, etc.

Not-Applicable
Once a threat has been moved into an Not-Applicable status, its risk is no longer impacting the overall risk of the threat model. Those threats will also be excluded from the Risk Summary Report. By default, N/A threats are hidden from view in the threats interface. They can be added back into the view by unselecting the “Hide NA Threats” under the view icon.

Ease of Exploitation
This value for a threat represents the relative ease to realize this threat. Low Ease of Exploitation would represent that something is more difficult vs a High Ease of Exploitation which would represent a threat that requires less skill and is easier to carry out.

Standard
In IriusRisk, standards effectively move a countermeasure from a recommended to required status. Functionally, they are attached to standards and include a reference number which might correspond to external industry or internal documentation (AC - 1.1).

Countermeasure
Countermeasures or controls are the planned mitigation or risk reducing items which are leveraged to reduce the inherent risk of a project or threat model. They can be in multiple states: recommended, required, implemented.

Count. Progress
Abbreviated from Countermeasure progress, is a visual indicator of the completion status of any required countermeasures. Recommended countermeasures are not included in the visual indicator, only those that are in the Required state.

Risk Key terms

Risk
Risk is a function of threat impact multiplied against the likelihood of realization.

Risk Response
Risk response is a visual indicator of the threat model practitioner progress on reducing the risk on a specific threat.

Risk Pattern
Inside of IriusRisk, we use risk patterns to group sets of threats together for application to a threat model. Most of the time when a component is added to a project, it will bring an entire risk pattern into IriusRisk. Risk patterns are composed of Use Cases which are composed of Threats.

Other Key terms

Owner
The owner of a threat is the user or group of users who are responsible for mitigating, updating, or removing this threat.

Templates
Full threat models, frameworks for threat models.

Project Components
Nested threat models that are used as components